

Правовое регулирование оборота персональных данных

Персональные данные

Персональные данные - это любая информация, относящаяся к прямо или косвенно определенному или определяемому физическому лицу (субъекту персональных данных).



- для юридических лиц — от 1 000 000 до 1 500 000 руб.

Единственным положительным моментом здесь является то, что данное административное нарушение не влечет за собой приостановку деятельности организации.

Примеры обработки персональных данных на сайте

Персональные данные на сайте могут обрабатываться 2 способами. К примеру, посетитель хочет зарегистрироваться, чтобы получить доступ к закрытому контенту. В таком случае он должен заполнить форму со следующими полями:

- e-mail;
- номер телефона;
- ФИО;
- дата рождения.

Второй пример сбора персональных данных подразумевает использование cookie. В этом случае можно получить следующую дополнительную информацию:

- IP;
- геолокация пользователя;
- сведения о действиях на сайте.

Кто такой оператор персональных данных и когда им становятся





[О премии](#) [Условия участия](#) [Номинации](#) [Экспертный совет](#) [Победители](#) [Партнеры](#) [Блог](#) [Контакты](#)

[Подать заявку](#)

Сроки уничтожения персональных данных

7

рабочих дней

При представлении субъектом персональных данных (или его представителем) сведений, подтверждающих, что персональные данные являются незаконно полученными или не являются необходимыми для заявленной цели обработки

(ч. 1 ст. 14, ч. 3 ст. 20 Закона N 152-ФЗ)

10

рабочих дней

При выявлении неправомерной обработки персональных данных, если персональные данные закон фз невозможно обеспечить ее правомерность – срок считается с даты выявления

(ч. 3 ст. 21 Закона N 152-ФЗ)

30

рабочих дней

При достижении цели обработки персональных данных – срок отсчитывается с даты достижения цели

(ч. 4 ст. 21 Закона N 152-ФЗ)

30

рабочих дней

При отзыве субъектом персональных данных согласия на обработку его персональных данных, если их сохранение более не требуется для целей обработки персональных данных - срок отсчитывается с даты поступления отзыва

(ч. 5 ст. 21 Закона N 152-ФЗ)



— АПОСТОЛ —
БРЕНД-МЕД
Гайд для успешного





10

рабочих дней

При выявлении неправомерной обработки персональных данных, если невозможно обеспечить ее правомерность – срок считается с даты выявления

(ч. 3 ст. 21 Закона N 152-ФЗ)

30

рабочих дней

При достижении цели обработки персональных данных – срок отсчитывается с даты достижения цели

(ч. 4 ст. 21 Закона N 152-ФЗ)

30

рабочих дней

При отзыве субъектом персональных данных согласия на обработку его персональных данных, если их сохранение более не требуется для целей обработки персональных данных - срок отсчитывается с даты поступления отзыва

(ч. 5 ст. 21 Закона N 152-ФЗ)

10

рабочих дней

При обращении субъекта персональных данных с требованием о прекращении обработки персональных данных - срок отсчитывается со дня получения такого требования, за исключением отдельных случаев. Данный срок может быть продлен, но не более чем на 5 рабочих дней

(ч. 5.1 ст. 21 Закона N 152-ФЗ)



Удаляем персональные данные из общего доступа: нововведения с 1 марта

3 марта 2021

Маргарита Сазонова

1 марта вступили в силу поправки в Федеральный закон от 27 июля 2006 г. № 152-ФЗ "О персональных данных" (далее – Закон № 152-ФЗ). На кого распространяется новый закон, при каких условиях и каким образом можно удалить свои персональные данные из общего доступа – в нашем материале.

Зачем нужен новый закон?

Закон направлен на создание механизмов защиты прав и свобод субъектов персональных данных, чьи персональные данные участвуют в общедоступном обороте. В соответствии с мнением депутатов Госдумы, действующая на момент внесения законопроекта правовая конструкция позволяла третьим лицам осуществлять сбор и последующее неконтролируемое использование указанных персональных данных на интернет-сайтах в целях, отличных от цели их первоначального распространения, а равно с ориентиром на иные целевые аудитории, что нарушает принцип целеполагания, установленный ст. 5 Закона № 152-ФЗ.



vladimirobradovic75@gmail.com / Depositphotos.com

Теперь субъект персональных данных имеет право обратиться к любому оператору персональных данных с требованием удалить его персональные данные из общего доступа без дополнительных условий доказывания факта неправомерной обработки персональных данных. Требовать от оператора блокирования или уничтожения персональных данных можно было и раньше, однако с соблюдением условия – необходимо было доказать, что они являются неполными, устаревшими, неточными, незаконно полученными или не являются необходимыми для заявленной цели обработки, а также принимать предусмотренные законом меры по защите своих прав (в соответствии с ч. 1 ст. 14 Закона № 152-ФЗ). Новый закон позволяет осуществлять соответствующие запросы только по причине того, что персональные данные принадлежат субъекту.

Основное отличие нововведений от предыдущей правовой конструкции заключается в том, что любой человек теперь сам может принять решение в отношении того, какие персональные данные могут использоваться публично. Субъект персональных данных сам устанавливает их перечень, при этом причины можно не указывать – оператор обязан удалить данные из общего доступа просто потому, что они относятся к определенному или определяемому лицу. Согласие должно быть выражено отдельно от других согласий на обработку персональных данных.

Что нового вводит закон в отношении законодательства о персональных данных

Поправки вводят новый термин – персональные данные, разрешенные субъектом персональных данных для распространения. К таким относятся такие персональные данные, доступ неограниченного круга лиц к которым предоставлен их субъектом (ст. 152-ФЗ). Такое разрешение выражается путем дачи согласия на обработку персональных данных. Согласие должно оформляться отдельно от

ЗАКОН О ПЕРСОНАЛЬНЫХ
ДАННЫХ 152-ФЗ



РЕКЛАМА
teplye-besedy.ru

Сиделка не справляется

WwajUA9Q3

нный доступ
ГАРАНТ
на 3 дня!

доступ

Оператор персональных данных

Оператор — любая организация, ИП и физическое лицо, которое обрабатывает персональные данные, например, собирает электронные адреса для рассылки.



Хостинг

1) Хостинг и база данных с персональными данными должна располагаться на территории России.



ХОСТИНГ

В соответствии с ФЗ № 152, все интернет-ресурсы, на которых хранятся и обрабатываются персональные данные, должны быть расположены на территории Российской Федерации. С учётом того, что контролирующие органы считают персональными данными также и данные о поведении пользователя на сайте, то это касается практически любого интернет-ресурса. За нарушение этого требования Роскомнадзор их блокирует.



Согласие на обработку персональных данных

Под каждой формой сбора данных разместить текст «Нажимая на кнопку, вы даете согласие на обработку своих персональных данных». Ссылка должна вести на страницу с **Политикой обработки персональных данных**. Если это форма подписки на рассылку, то текст должен быть с чекбоксом, где пользователь сам должен поставить галочку.

Либо же можно сделать отдельную форму согласия на обработку персональных данных.

Зачем нужна ссылка на Политику обработки персональных данных?

Это нужно для того, чтобы пользователь мог с ней ознакомиться, согласиться и только после этого сообщить свои персональные данные.



Обращения пользователей по поводу персональных данных

Укажите email в Политике обработки персональных данных, куда лицо может обратиться за тем, чтобы его персональные данные были удалены, заблокированы и вообще, куда он может задать вопрос по персональным данным.

Важно, чтобы указанный email был рабочим, информация на нем регулярно проверялась, чтобы не пропустить запрос пользователя на удаление персональных данных с сайта.

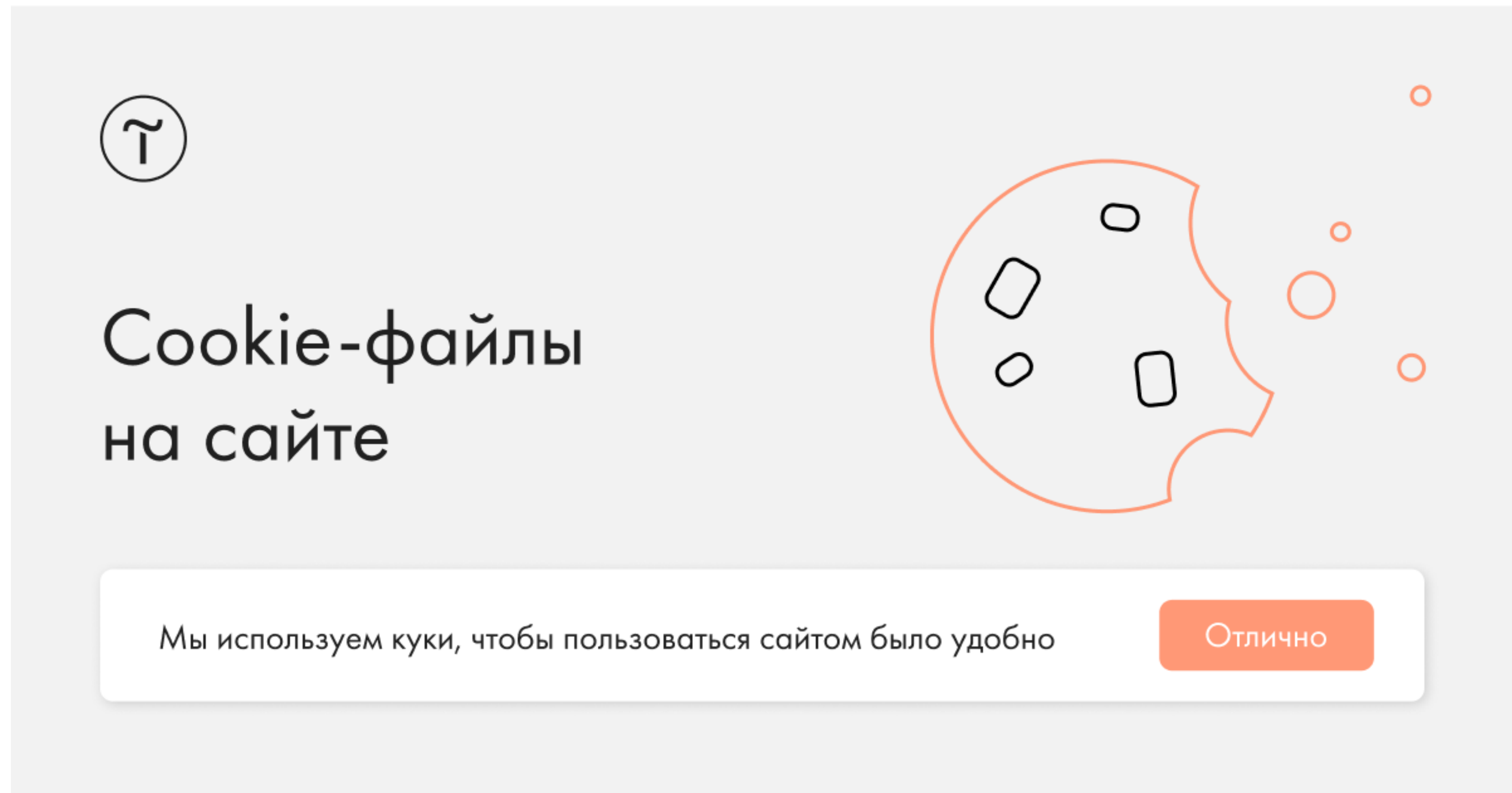
Сбор и обработка метаданных

Необходимо показывать всем новым пользователям сайта предупреждение с текстом о том, что вы собираете метаданные пользователя (cookie, данные об IP-адресе и местоположении) для функционирования сайта и, если он не хочет, чтобы эти его данные обрабатывались, то должен покинуть сайт.



Как предупредить?

Предупредить пользователей можно с помощью небольшого всплывающего блока с кнопкой «Согласен».



Реестр Роскомнадзора

Подать уведомление, чтобы внести организацию в реестр операторов персональных данных Роскомнадзора — можно сделать через сайт.

The screenshot shows the official website of the Federal Service for Supervision of Communications, Information Technologies, and Mass Communications (Roskomnadzor). The page is titled "Реестр операторов, осуществляющих обработку персональных данных" (Register of operators processing personal data). It includes a search bar, a sidebar with navigation links, and a table of search results.

ФЕДЕРАЛЬНАЯ СЛУЖБА ПО НАДЗОРУ В СФЕРЕ СВЯЗИ, ИНФОРМАЦИОННЫХ ТЕХНОЛОГИЙ И МАССОВЫХ КОММУНИКАЦИЙ

Роскомнадзор

Массовые коммуникации | Связь | Персональные данные | Информационные технологии | Государственные услуги

Главная страница > Персональные данные

Реестр операторов, осуществляющих обработку персональных данных

Результат поискового запроса отображает информацию не более чем о 100 операторах.

Для наиболее точного и быстрого поиска в реестре достаточно указать ИНН организации. В случае, если Вы не знаете точный ИНН, можно произвести поиск по наименованию. При этом достаточно указать только оригинальную его часть (одно или несколько слов, которые отличают данную организацию от других) без указания организационно-правовой формы, специмболов, кавычек и сокращений. Если наименование состоит из двух и более слов, в том числе разделенных дефисом, достаточно указать только одно из этих слов. Советуем избегать часто встречающихся в наименовании организации слов, например, таких как: "Российский", "Федеральный", "Общество" и т.п.

Организация:

ИНН: Регистрационный номер:

В настоящее время в реестре содержатся данные о **401 241** операторах персональных данных (по состоянию на 29.10.2019)

[Найти](#)

Регистр. номер	Наименование оператора / ИНН	Тип оператора	Основание исключения	Дата регистрации уведомления	Дата начала обработки
77-16-004848	Публичное акционерное общество "Газпром" ИНН: 7736050003	юридическое лицо	Приказ № 65 от 19.04.2016	13.04.2016	25.02.1993

Всего: 1

Территориальные управления

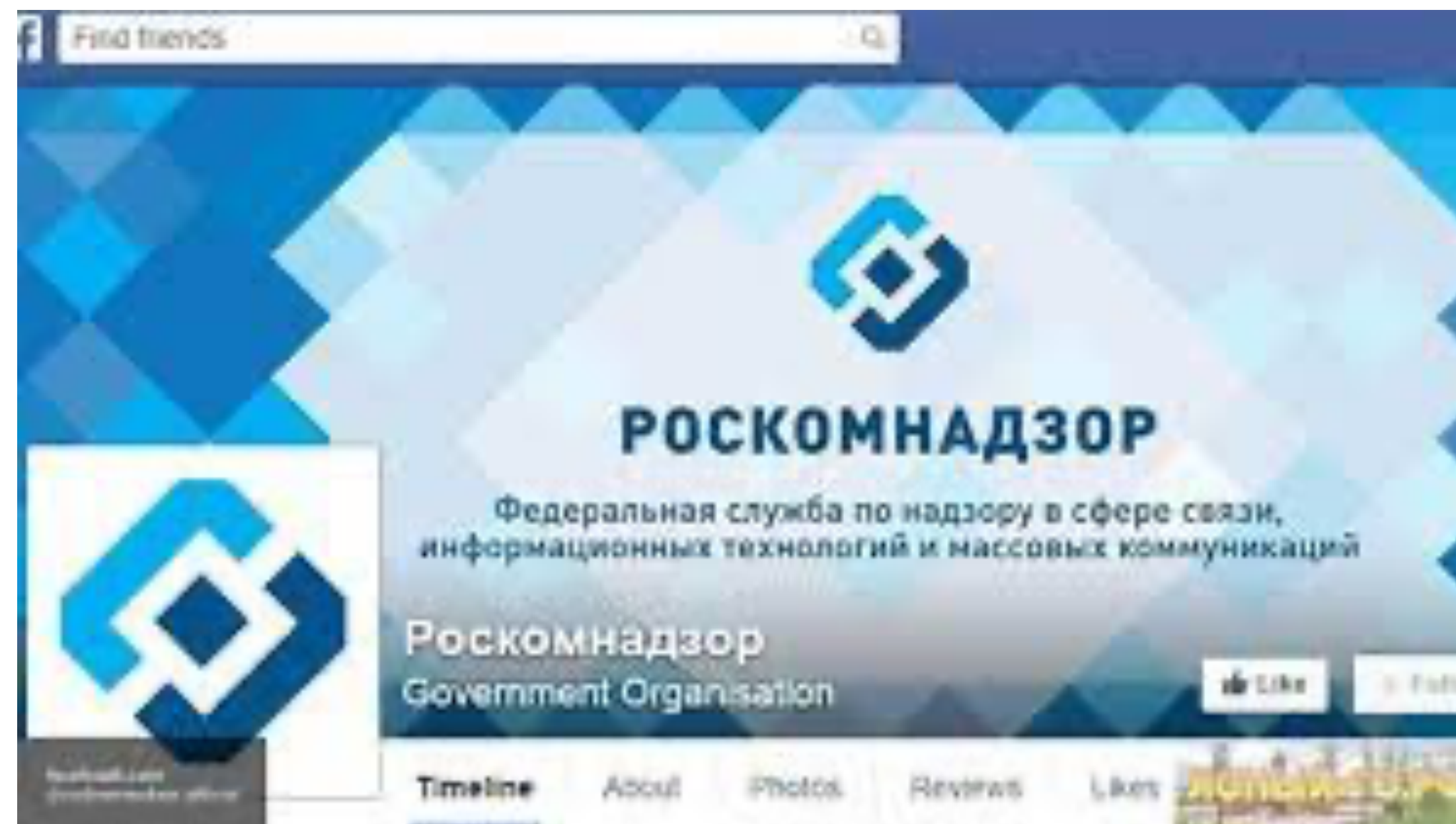
Когда можно не подавать уведомление?

Если:

- обрабатываются только данные работников и только для исполнения требований трудового законодательства (без передачи данных в банки, например, оформления зарплатного проекта);
- обрабатываются данные, заключая договор с каждым клиентом и работником, и не передаются данные третьим лицам;
- обрабатываются персональные данные только на бумажных носителях.

Последствия

Если проверка выявит нарушения, то Роскомнадзор может заблокировать сайт, наложить штрафы и в редких случаях приостановить деятельность компании.



Обработка персональных данных не в заявленных целях

Обработка персональных данных не в тех целях, о которых было заявлено: для **ИП** и **юридических лиц** - штраф от **150 000** до **300 000** рублей.

В случае повторного нарушения:
для **ИП** и для **юридических лиц** - от **300 000** до **500 000** рублей.

Обработка персональных данных без согласия пользователя

Обработка персональных данных без согласия пользователя либо тех данных, которые не были указаны в согласии пользователя (например, в форме обратной связи нет ссылки на соглашение на обработку персональных данных):
для **ИП и юридических лиц** – штраф от **300 000** до **700 000** рублей.

В случае повторного нарушения:
для **ИП** - штраф от **500 000** до **1 000 000** рублей; для **юридических лиц** - от **1 000 000** до **1 500 000** рублей.

Отсутствует Политика обработки персональных данных

Если на сайте **нет Политики обработки персональных
данных:**

**для ИП - штраф от 10 000 до 20 000 рублей; для
юридических лиц - от 30 000 до 60 000 рублей.**

Непредоставление пользователю информации о его персональных данных

Если вы не предоставите пользователю информацию, касающейся обработки его персональных данных:

для **ИП** - штраф от **20 000** до **30 000** рублей; для **юридических лиц** - от **40 000** до **80 000** рублей.

Неудовлетворение требования пользователя об уточнении/удалении персональных данных

Если вам напишет пользователь и попросит уточнить или удалить его персональные данные с вашего сайта, а вы **не сделаете** (если эти персональные данные являются неполными, устаревшими, неточными, незаконно полученными или не являются необходимыми для заявленной цели обработки):

для **ИП** — штраф от **20 000** до **40 000** рублей; для **юридических лиц** — от **50 000** до **90 000** рублей.

В случае повторного нарушения:

для **ИП** - штраф от **50 000** до **100 000** рублей; для **юридических лиц** - от **300 000** до **500 000** рублей.

Нарушение сохранности в отношении персональных данных

Невыполнение **требования сохранности материальных носителей персональных данных и исключаящих несанкционированный к ним доступ**, если это повлекло **неправомерные действия в отношении персональных данных:**
для **ИП** - штраф от **20 000** до **40 000** рублей; для **юридических лиц** - от **50 000** до **100 000** рублей.

Нарушение сохранности в отношении персональных данных

Невыполнение требования по обеспечению записи, систематизации, накопления, хранения, уточнения или извлечения персональных данных граждан Российской Федерации с использованием баз данных, находящихся на территории Российской Федерации (хостингу):

для **ИП и юридических лиц** - штраф от **1 000 000** до **6 000 000** рублей.

В случае повторного нарушения:

для **ИП и юридических лиц** - штраф от **6 000 000** до **18 000 000** рублей.

Выводы

- Предоставление согласия должно быть явным (галочка)
- Должны быть указаны данные, которые предоставляются
- Должны быть указаны технологии, которые используются, и цели обработки, включая рекламные

Выводы

- Должно быть указано, каким третьим лицам могут быть переданы персональные данные
- Должна быть предусмотрена возможность отзыва предоставленного пользователем согласия

Новое в законодательстве о персональных данных

Принцип экстерриториальности применения законодательства о персональных данных.



Новое в законодательстве о персональных данных

Уведомление оператором персональных данных Роскомнадзора о трансграничной передаче персональных данных (включая дату проведения оператором оценки соблюдения получателем ПД конфиденциальности и обеспечения безопасности при их обработке).



Новые обязанности оператора персональных данных

Оператор персональных данных обязан уведомлять Роскомнадзор о компьютерных инцидентах, повлекших нарушение прав субъектов персональных данных. Обязанность возникает с момента выявления компьютерного инцидента и предполагает направление двух уведомлений:

- в течение 24 часов направляется уведомление с информацией об инциденте. В уведомлении указываются сведения: *об инциденте, о предполагаемых причинах, о предполагаемом вреде, о мерах, принятых для устранения последствий;*
- в течение 72 часов – *о результатах внутреннего расследования инцидента, о лицах, действия которых стали причиной инцидента.*

Новые обязанности оператора персональных данных

Оператор персональных данных должен провести внутреннее расследование компьютерного инцидента в течение 3 суток с момента его обнаружения.



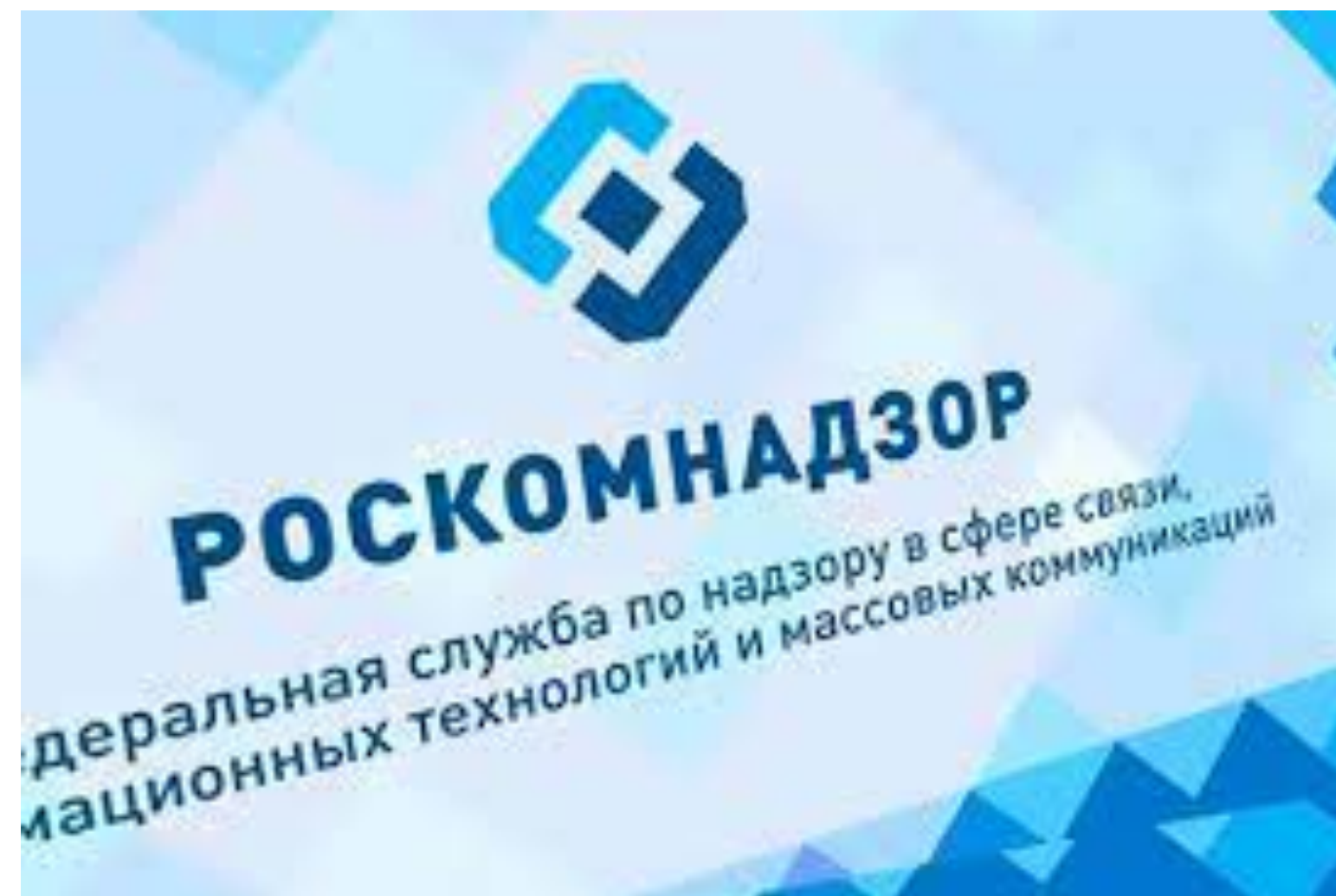
Новые обязанности оператора персональных данных

Оператор обязан обеспечивать взаимодействие с Государственной системой обнаружения, предупреждения и ликвидации последствий компьютерных атак на информационные ресурсы (ГосСОПКА), информировать о компьютерных инцидентах, которые повлекли неправомерную передачу персональных данных.

Оператор персональных данных обязан уведомлять ФСБ о компьютерных инцидентах, которые произошли в результате неправомерных действий.

Сокращен срок ответа Роскомнадзору

Срок на исполнение запроса Роскомнадзора сокращен с 30 до 10 рабочих дней с даты его получения. Срок может быть продлен на основании мотивированного уведомления оператора не более чем на 5 рабочих дней.



Согласие на обработку персональных данных

Ранее: согласие субъекта персональных данных должно быть **информированным, конкретным, сознательным.**

Теперь: согласие также должно быть *предметным и однозначным.*

Данные критерии являются оценочными, их содержание в законе не раскрывается.

Право на забвение

Статья 10.3. Обязанности оператора поисковой системы

(введена Федеральным законом от 13.07.2015 N 264-ФЗ)

 1. Оператор поисковой системы, распространяющий в сети "Интернет" рекламу, которая направлена на привлечение внимания потребителей, находящихся на территории Российской Федерации, по требованию гражданина (физического лица) (далее в настоящей статье - заявитель) обязан прекратить выдачу сведений об указателе страницы сайта в сети "Интернет" (далее также - ссылка), позволяющих получить доступ к информации о заявителе, распространяемой с нарушением законодательства Российской Федерации, являющейся недостоверной, а также неактуальной, утратившей значение для заявителя в силу последующих событий или действий заявителя, за исключением информации о событиях, содержащих признаки уголовно наказуемых деяний, сроки привлечения к уголовной ответственности по которым не истекли, и информации о совершении гражданином преступления, по которому не снята или не погашена судимость.

 2. Требование заявителя должно содержать:

- 1) фамилию, имя, отчество, паспортные данные, контактную информацию (номера телефона и (или) факса, адрес электронной почты, почтовый адрес);
- 2) информацию о заявителе, указанную в [части 1](#) настоящей статьи, выдача ссылок на которую подлежит прекращению;
- 3) указатель страницы сайта в сети "Интернет", на которой размещена информация, указанная в [части 1](#) настоящей статьи;

Новости

2 апреля

Обязательная маркировка затр
большее число товаров

2 апреля

Поправки о списании процентов
кредитам ряда военнослужащих
приняты в третьем чтении

Не пропустите

Самые важные новости для юри
март

2 апреля

Получить электронные копии
учредительных документов мож
помощью нового сервиса ФНС

[Все новости →](#)

Бесплатны
пробный д

Статья 17. Право на удаление ("право на забвение")

Статья 17 Право на удаление ("право на забвение")

Право на забвение

1. Субъект данных имеет право требовать от контролера незамедлительного удаления относящихся к нему персональных данных, контролер должен незамедлительно удалить персональные данные, если применяется одно из следующих оснований:

- (a) персональные данные больше не требуются для целей, для которых они были получены или обрабатывались в иных случаях;
- (b) субъект данных отзывает свое согласие, на основании которого согласно [пункту \(а\) Статьи 6\(1\)](#) или [пункту \(а\) Статьи 9\(2\)](#) проводилась обработка, и если отсутствует иное юридическое основание для обработки;
- (c) субъект данных возражает против обработки согласно [Статье 21\(1\)](#), и отсутствуют имеющую преимущественную юридическую силу законные основания для обработки, или субъект данных возражает против обработки согласно [Статье 21\(2\)](#);
- (d) персональные данные обрабатывались незаконно;
- (e) персональные данные должны быть уничтожены в целях соблюдения юридической обязанности согласно законодательству Союза или государства-члена ЕС, под действие которого подпадает контролер;
- (f) персональные данные собирались в отношении предоставления услуг информационного общества согласно [Статье 8\(1\)](#).

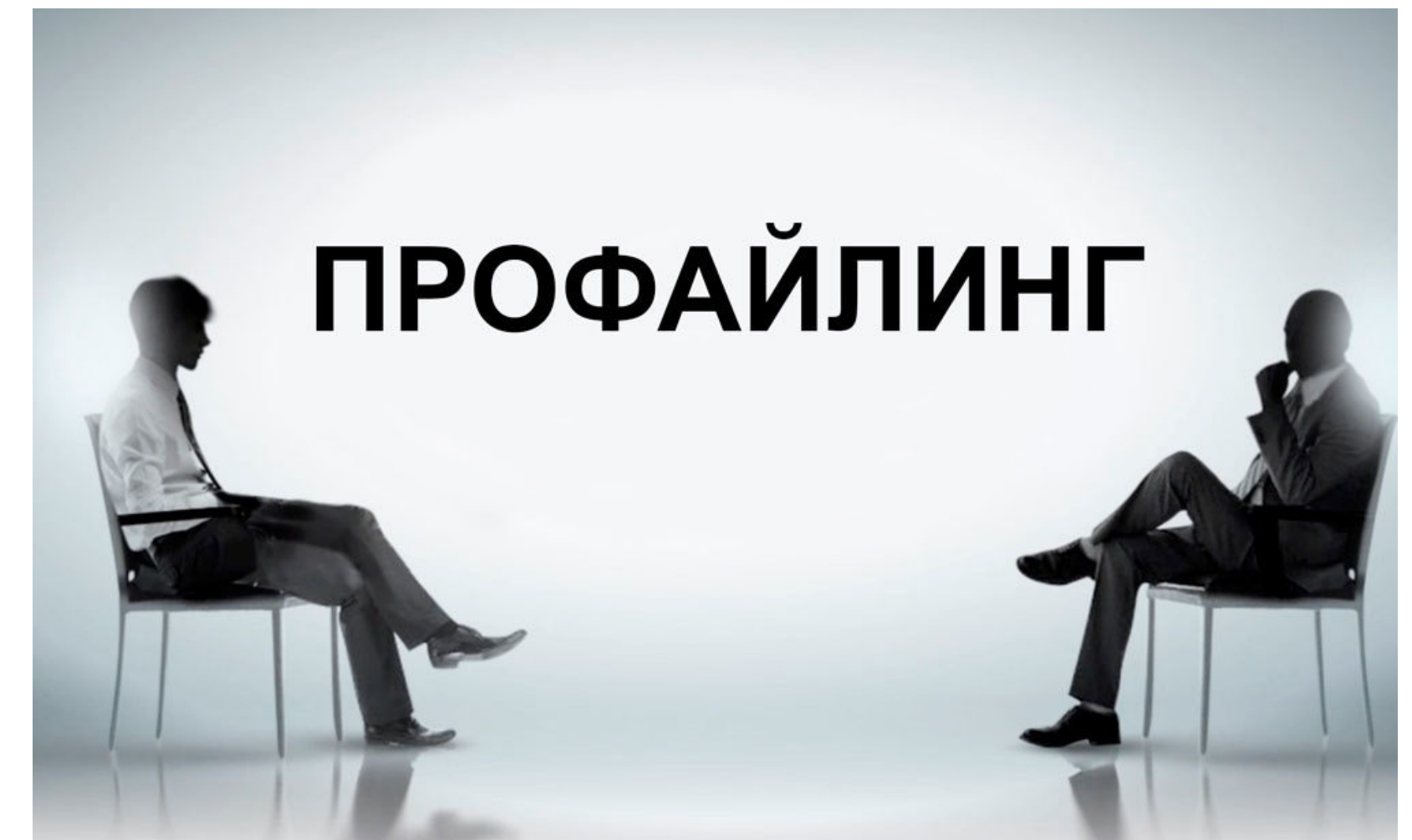
2. Если контролер обнаружил персональные данные и он согласно [параграфу 1](#) обязан удалить персональные данные, он с учетом имеющихся технологических возможностей и расходов на имплементацию должен принять необходимые меры, в том числе технические меры, чтобы проинформировать контролеров, которые обрабатывают персональные данные, о том, что субъект данных затребовал от них удаление любых ссылок, копий или точных повторений указанных персональных данных.

Право на забвение



Профайлинг

Профайлинг – понятие, обозначающее совокупность психологических методов и методик оценки и прогнозирования поведения человека на основе анализа наиболее информативных частных признаков, характеристик внешности, невербального и вербального поведения



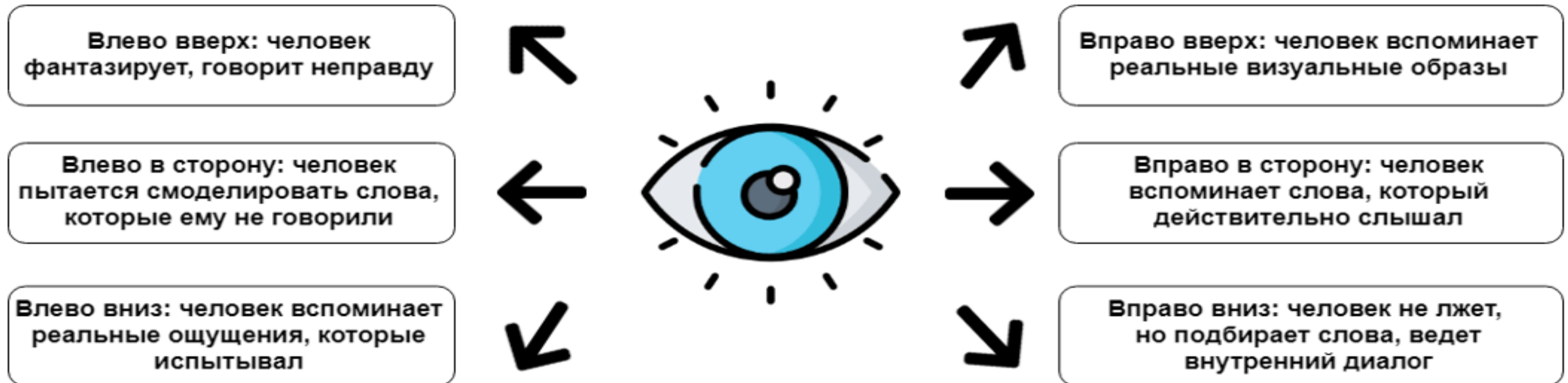
Формат работы профайлеров

1. Легендированное участие в переговорах и внутренних расследованиях

2. Анализ аудио- и видеозаписей переговоров

3. Тайный покупатель

Что означает направление взгляда человека?



Профайлинг: правовые границы дозволенного

Европейский Общий регламент по защите данных (GDPR)

В GDPR содержится определение «профайлинга» - это любая форма автоматизированной обработки информации, состоящая из использования персональных данных для оценки определенных аспектов, относящихся к физическому лицу, в частности, с целью проанализировать или предсказать его экономическую ситуацию, здоровье, личные предпочтения и интересы, работоспособность, надежность, поведение, местонахождение, перемещения.

Профайлинг: правовые границы дозволенного

1. Лицо должно быть проинформировано о проведении в отношении него профайлинга и о его последствиях
2. В случае если персональные данные обрабатываются для принятия решений в отношении конкретных лиц по итогам системной оценки информации на основе профайлинга, оператор должен провести «оценку воздействия на защиту персональных данных»

Профайлинг: правовые границы дозволенного

Механизмы контроля, которые устанавливает законодательство о персональных данных предусматривают меры, которые минимизируют риски за счет необходимости установления контакта с пользователями на ранних стадиях профайлинга и принятия организационно-технических мер защиты собираемых данных с момента их сбора

Профайлинг: правовые границы дозволенного

Ситуация: Банк и Компания заключили договор о предоставлении кредитной линии на общую сумму 50 000 000 руб. Компания осуществляла регулярные платежи по кредиту, однако в какой-то момент перечисление денежных средств прекратилось. В дальнейшем залоговое имущество исчезло, общая сумма задолженности перед Банком составила 45 078 000 руб.

Задача: графологу по образцам почерка определить благонадежность генерального директора Компании, подписавшего кредитный договор с Банком.

Фрагмент почерка с основными признаками неблагонадежности

справку по форме банка на 3/4 - 100 000
(свои деньги) рублей и Ивана Трудов
Иван (заверенного работодателем)

- ♦ почерк нечитабельный — признак отсутствия ориентации на окружающих, двусмысленности, подмены понятий;
- ♦ нитеобразный (аморфный) — признак подверженности сиюминутному влиянию, отсутствия принципов, живет «куда ветер подует», также нитеобразность выступает признаком хорошей интуиции;
- ♦ отсутствует контроль при написании — признак отсутствия внутреннего контроля своего поведения, желаний,

живет как ему хочется, делает то, что хочется.

Конфиденциальность персональных данных в ситуации киберугроз



Утечка данных

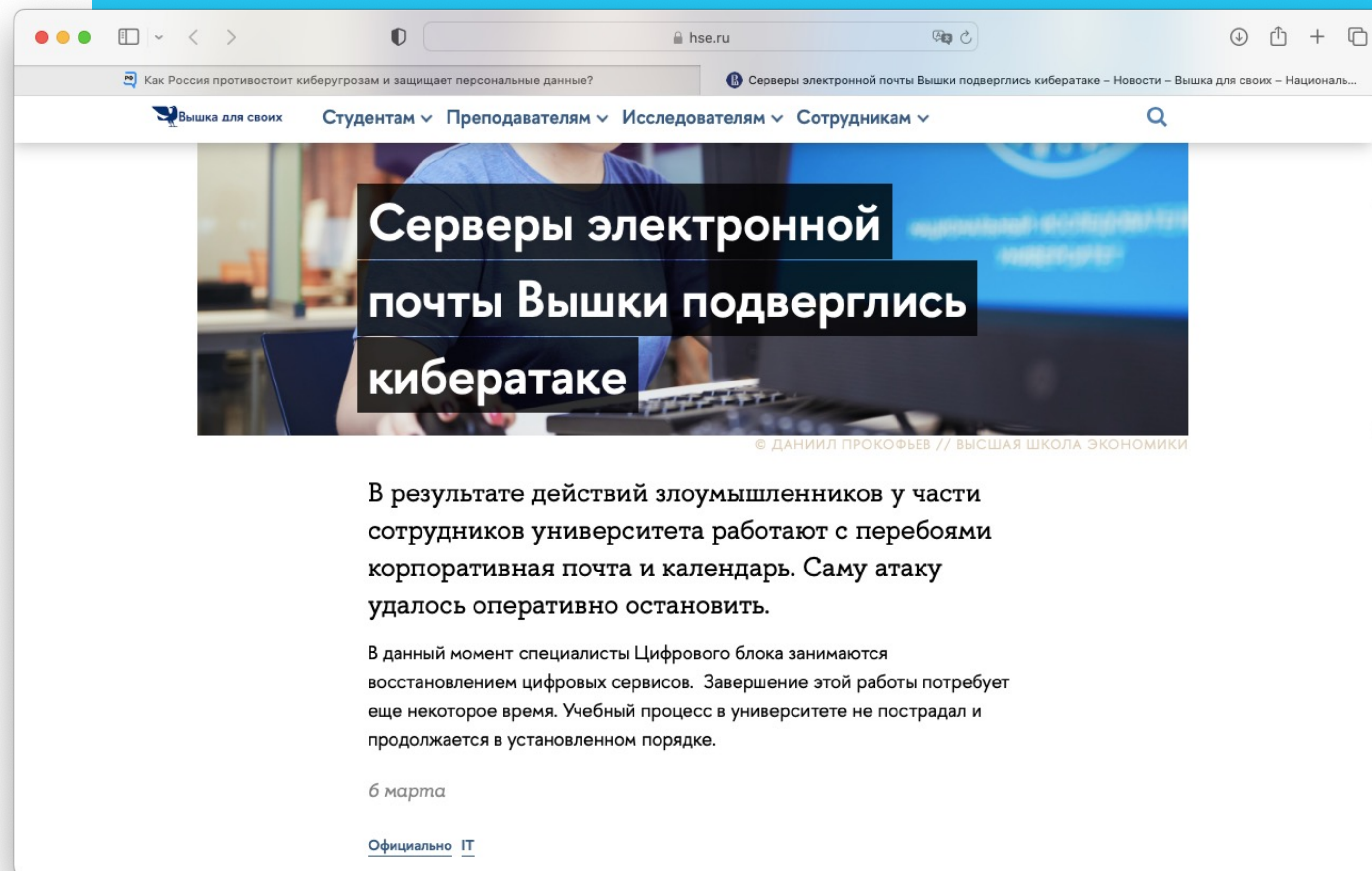


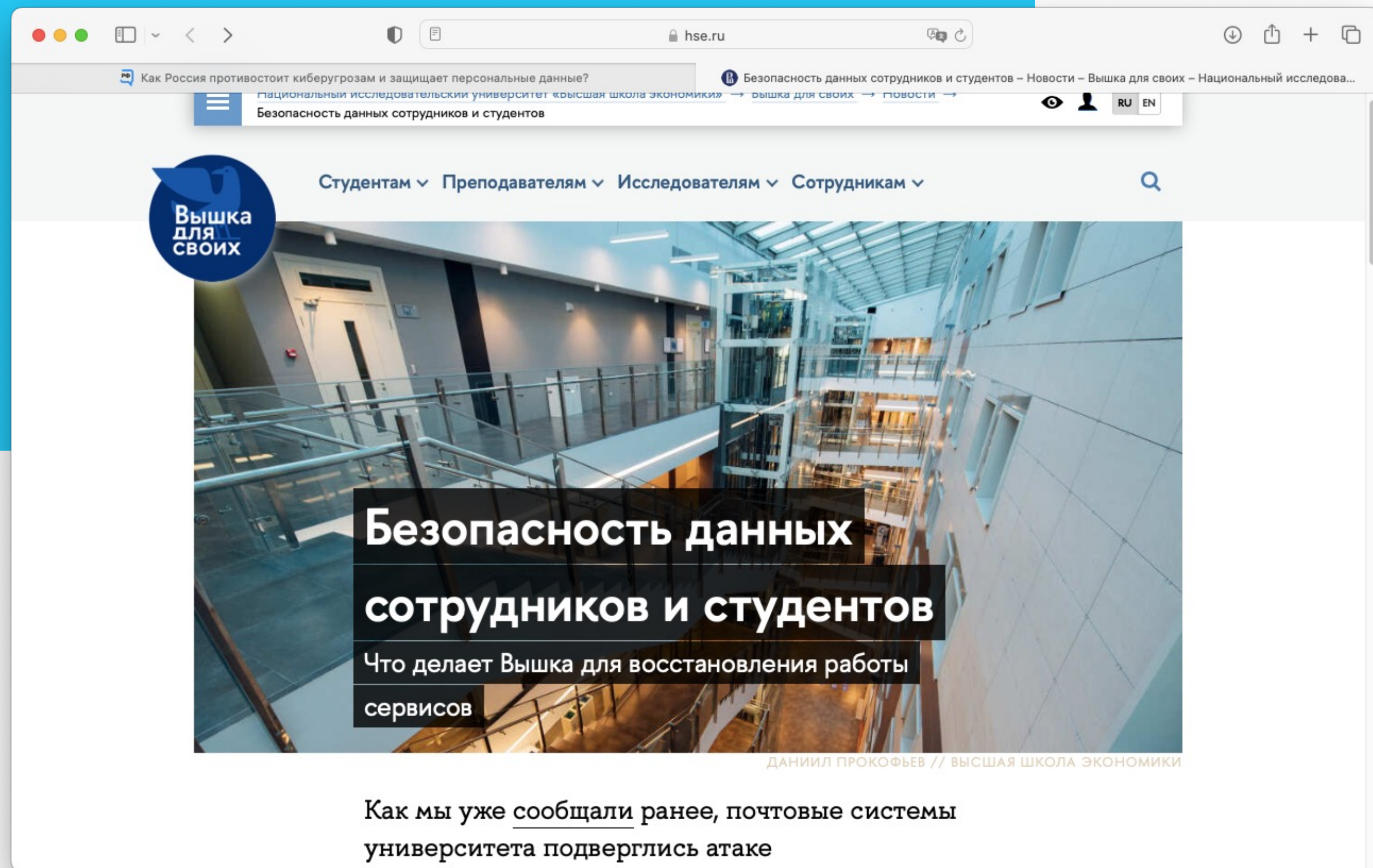
Данные абитуриентов, студентов, выпускников и сотрудников НИУ ВШЭ утекли в сеть — об этом сообщают Telegram-каналы

Утверждается, что в даркнете разместили персональные данные, полученные из баз НИУ ВШЭ: среди них сканы паспортов и персональные данные выпускников и сотрудников, списки научных сотрудников, имеющих отсрочку от мобилизации, досье абитуриентов магистерской программы университета, логины и пароли к СЭД и много-много другой информации, которая актуальна на март 2023 года.

Автор слива данных заявил, что это только начало.

6-го марта ВШЭ официально сообщала, что её серверы подверглись кибератаке, но ее удалось оперативно остановить.





9 марта появилось заявление ВШЭ о том, что "служба безопасности университета анализирует появившиеся сообщения о возможной утечке данных и уже предпринимает необходимые действия для защиты сотрудников и студентов".

- 9 марта 2023 года **Роскомнадзор** заявил, что проверит информацию о возможной утечке персональных данных выпускников и сотрудников ВШЭ. Уточняется, что оператор уведомил Роскомнадзор о произошедшей утечке в установленные законодательством сроки.
- Согласно закону «О персональных данных» оператор, допустивший утечку данных, обязан в течение суток самостоятельно сообщить о произошедшем в Роскомнадзор и в течение 72 часов – предоставить результаты внутреннего расследования с указанием причины утечки и виновных лиц.



Яндекс.Еда

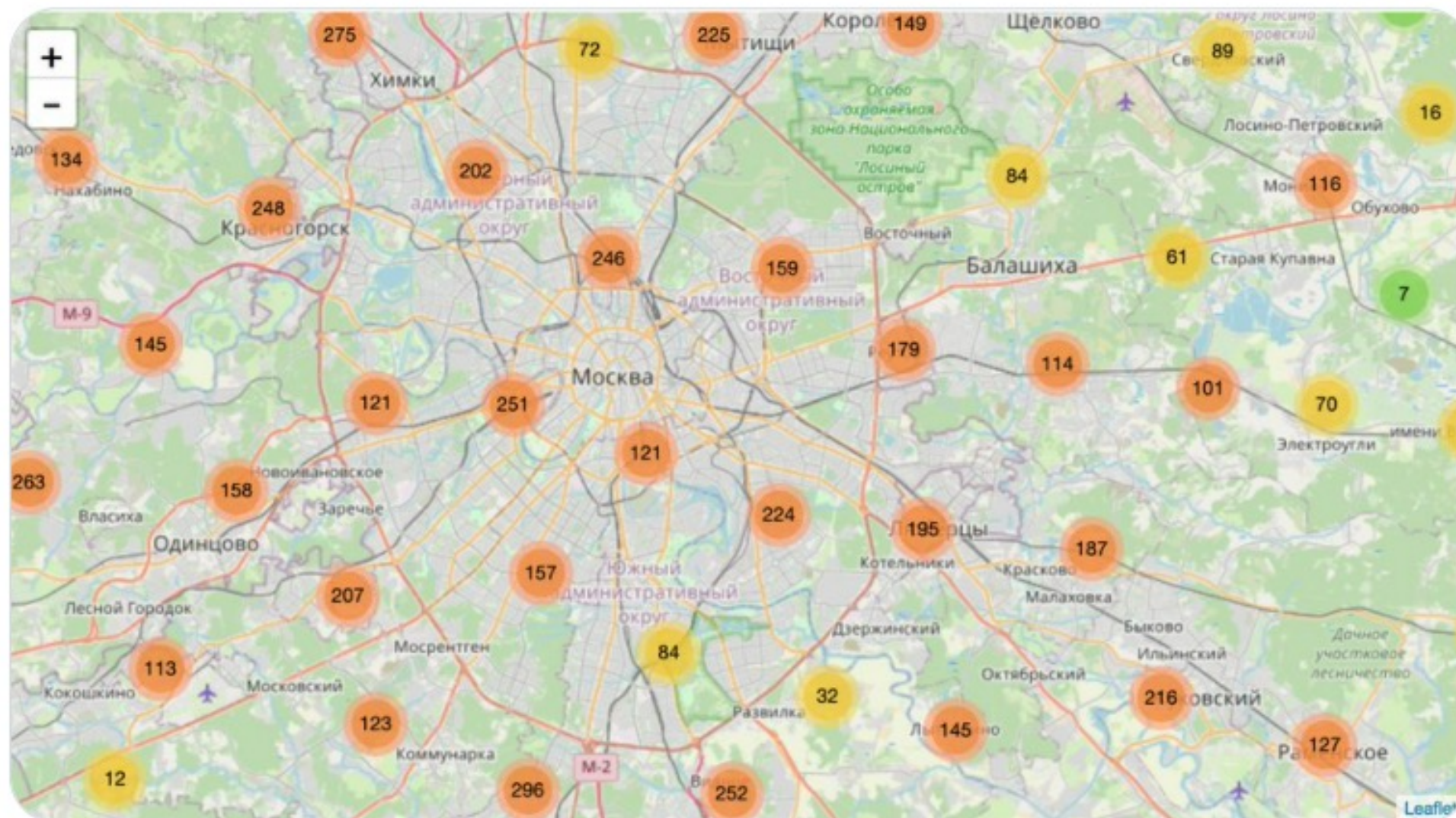


TJ @tjournal · 19m

В телеграм-каналах распространилась ссылка на карту с утёкшей информацией о пользователях «Яндекс.Еды» по месту их жительства. Среди слитых данных — имена, номера телефонов и адреса.

Сама утечка произошла ещё 1 марта, сейчас её визуализировали

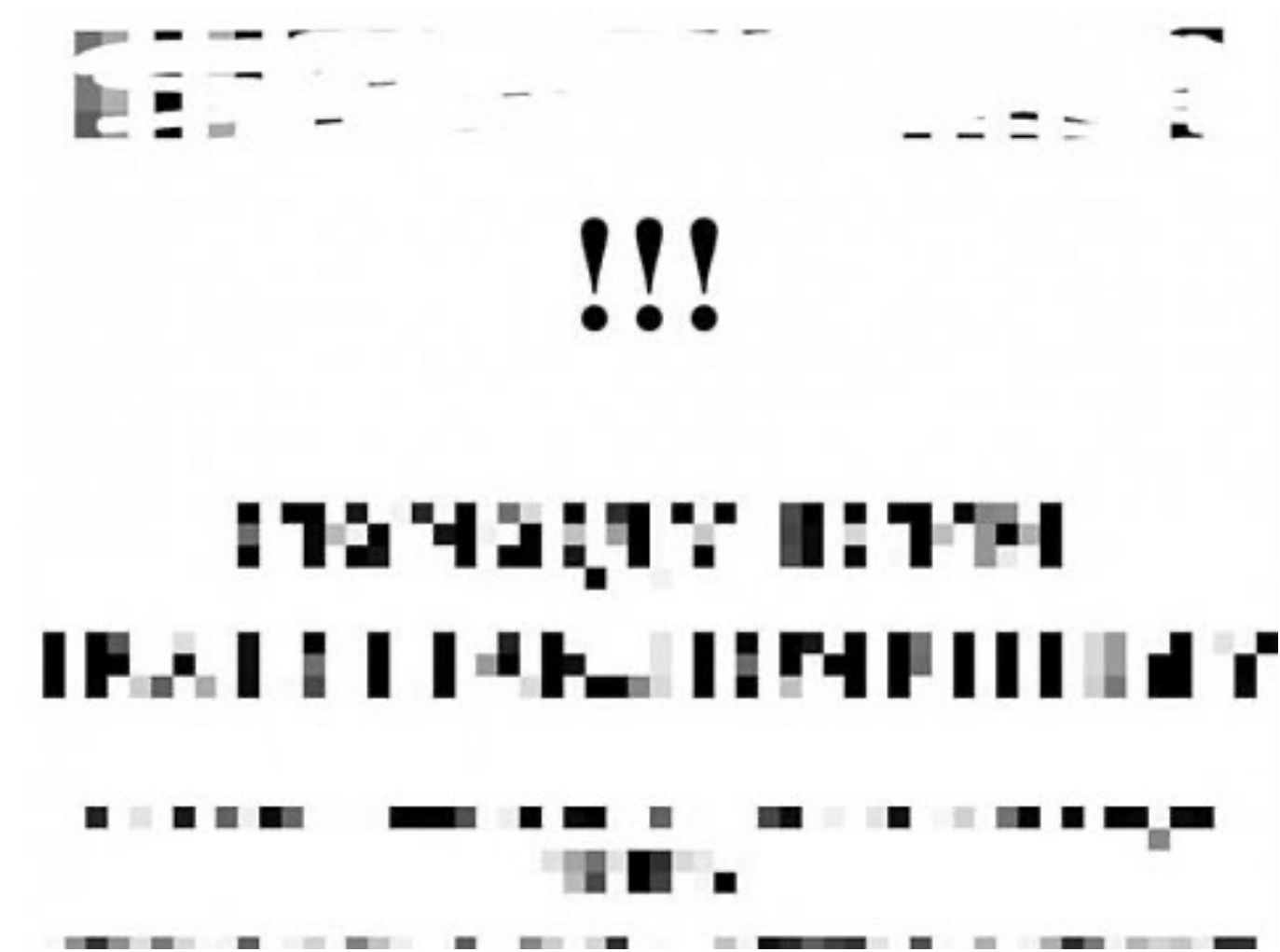
tjournal.ru/news/570305



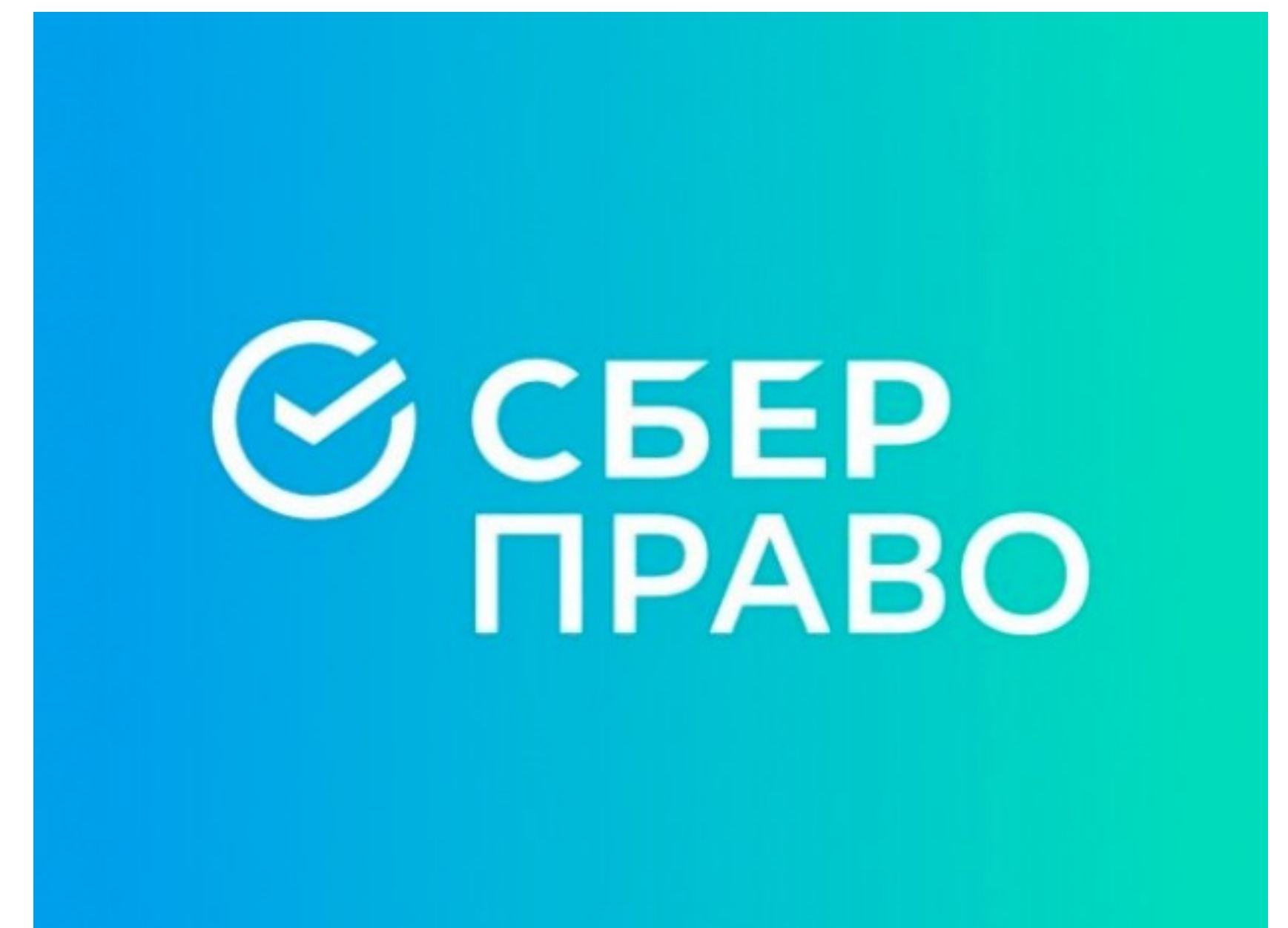
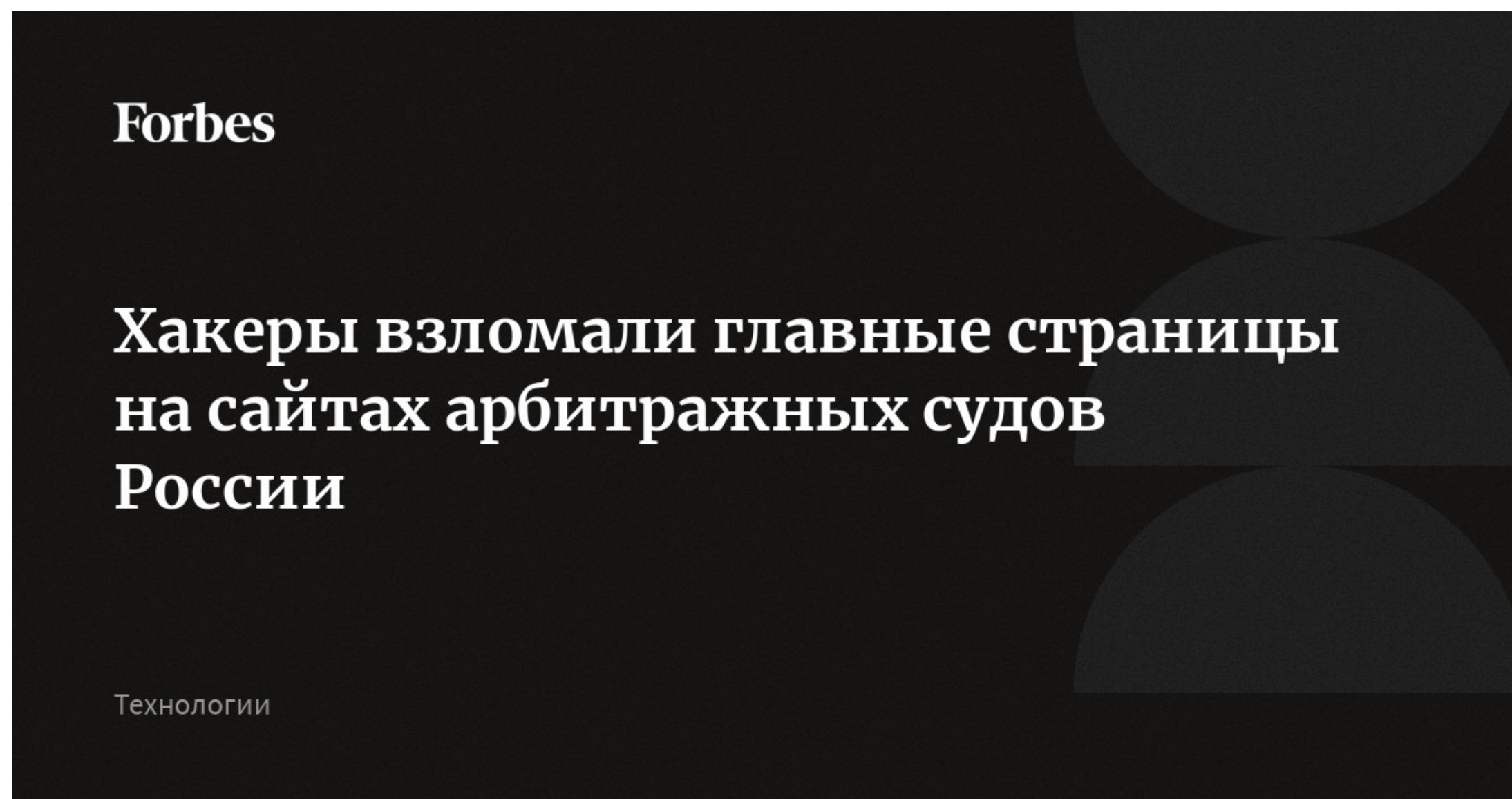
После глобальной утечки в Яндекс.Еде нужно было уже сделать выводы и принять превентивные меры для недопущения утечек данных в вузах, государственных базах данных и крупных компаниях.

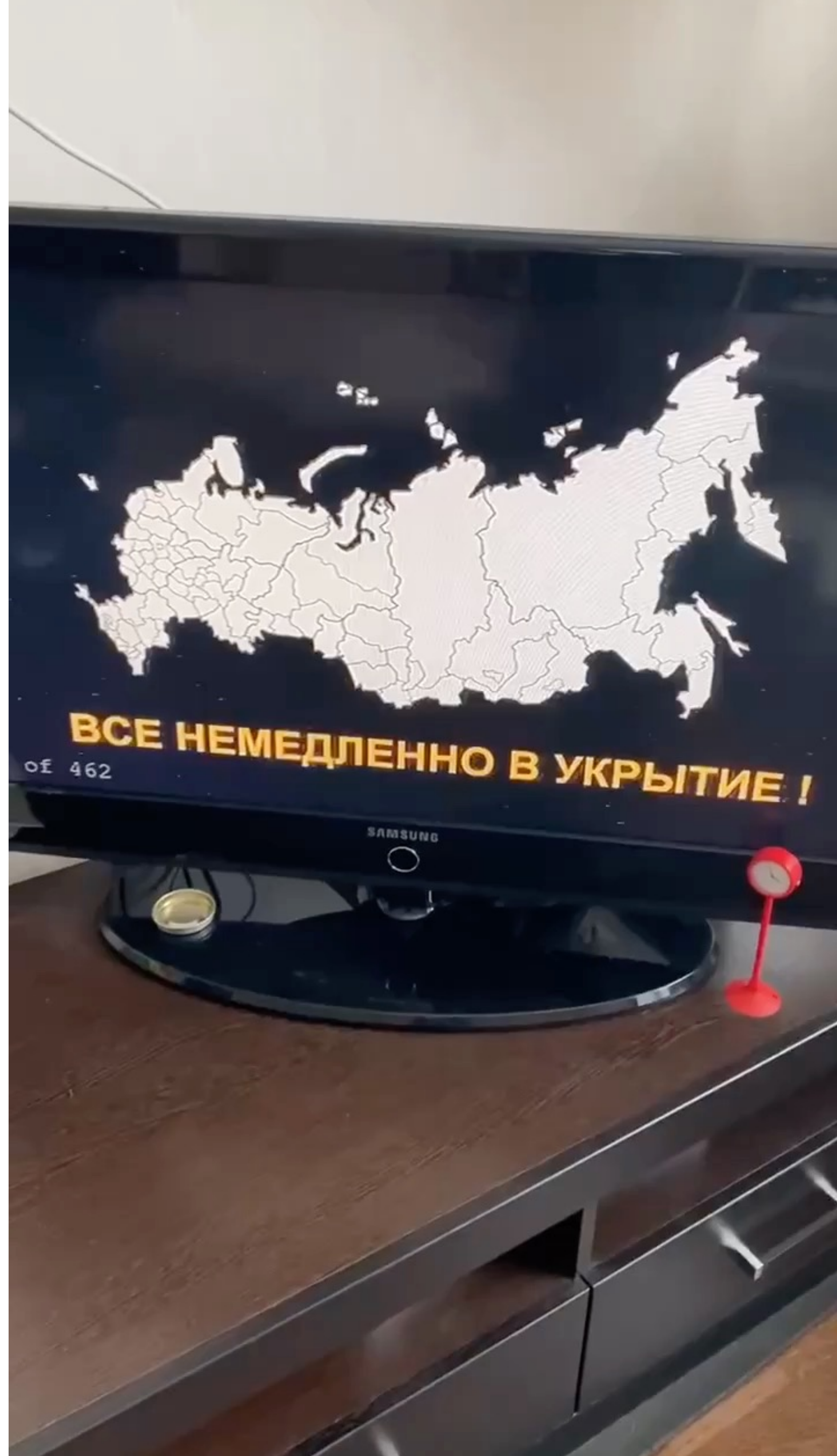
Почему утечки до сих пор происходят и чуть ли не каждый день?

Сайты арбитражных судов



Взлом государственных и иных сайтов





ГУ МЧС

В Москве после взлома серверов радиостанций и телеканалов в эфире прозвучала ложная информация о воздушной тревоге — ГУ МЧС.

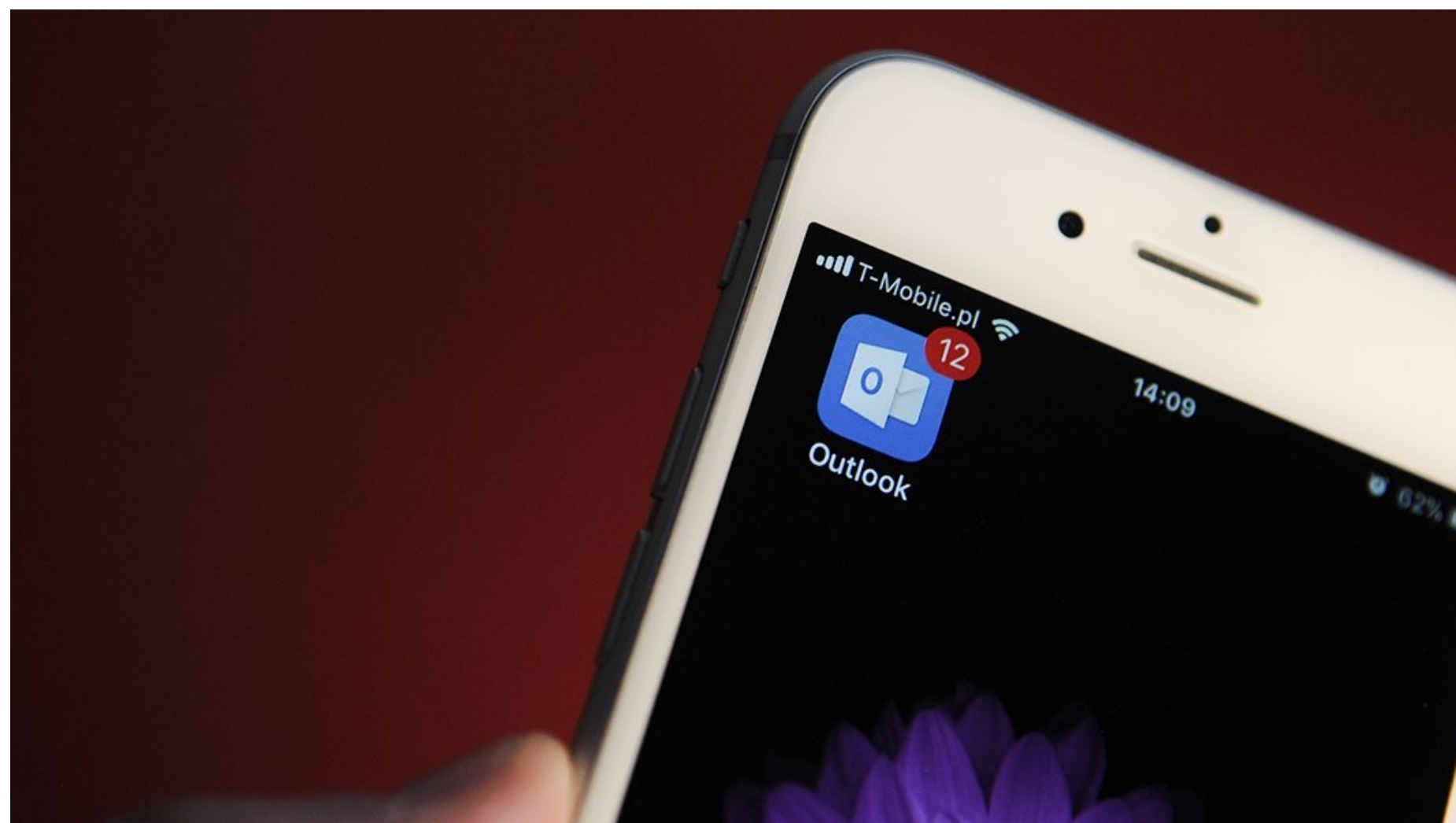


Риски

Облачные сервисы

ChatGPT: ажиотаж, интерес
пользователей





Корпорация Microsoft сообщила своим клиентам о хакерском взломе принадлежащего ей почтового клиента Outlook, сообщает телеканал CNN.



Указ Президента России от 1 мая 2022 года № 250 "О дополнительных мерах по обеспечению информационной безопасности Российской Федерации":

- устанавливается персональная ответственность за утечку данных
- в регионах созданы штабы по обеспечению кибербезопасности
- проводится регулярное стресс-тестирование систем
- к защите данных привлекаются специализированные организации



Приняты поправки в КоАП (ст. 13.11): размер штрафа зависит от числа пострадавших и составляет от 3 до 15 млн; за повторную утечку компанию будут штрафовать до 500 млн/на сумму до 3% от её выручки.

Предполагалось, что штраф может быть снижен, если компания проведет сертификацию своей инфраструктуры в соответствии с требованиями безопасности. Также в случае компенсации ущерба двум третям пострадавшим от утечки.



Приняты поправки в Уголовный кодекс: за незаконный сбор и распространение персональных данных нарушителя будут лишать свободы сроком до 5 лет; за создание сайта с незаконным оборотом таких сведений – до 5 лет лишения свободы и штраф до 700 тыс. руб.

Охватываются противоправные действия с использованием персональных данных: кража, продажа, а также создание теневых форумов, где незаконно распространяются личные данные граждан.



Соответствующие законодательные нормы имеются, были приняты поправки, но достаточны ли они? Достаточно ли только заявить об имевшемся инциденте?

** П. 3.1 ст. 21 ФЗ «О персональных данных» ... уведомить Роскомнадзор: 1) в течение двадцати четырех часов о произошедшем инциденте, о предполагаемых причинах, повлекших нарушение прав субъектов персональных данных, и предполагаемом вреде, нанесенном правам субъектов персональных данных, о принятых мерах по устранению последствий соответствующего инцидента, а также предоставить сведения о лице, уполномоченном оператором на взаимодействие с уполномоченным органом по защите прав субъектов персональных данных, по вопросам, связанным с выявленным инцидентом; 2) в течение семидесяти двух часов о результатах внутреннего расследования выявленного инцидента, а также предоставить сведения о лицах, действия которых стали причиной выявленного инцидента (при наличии).*

Поиграть

Поесть

Мах

Потратить

Послушать

Погулять

Посмотреть

Стать лучше

Покататься

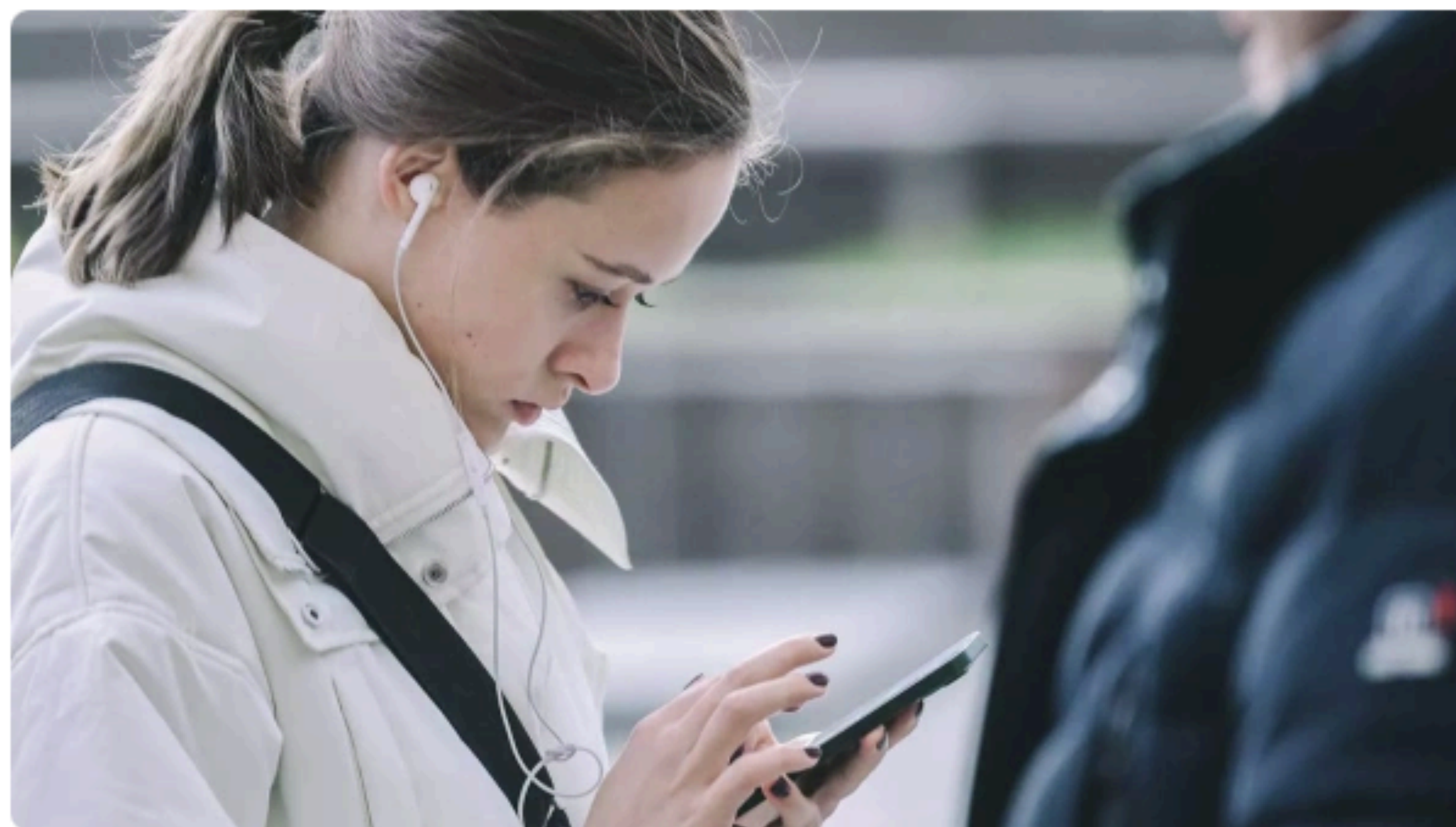
Почитать

Общество · 16 января, 13:17

РКН зафиксировал 135 случаев утечки данных россиян в 2024 году. В Сеть попало 710 млн записей о россиянах

В 2024 году Роскомнадзор зафиксировал утечку 710 млн данных о россиянах

Обновлено 16 января 2025, 13:30



Прогноз погоды в
вашем городе

Темы

Портреты

Смартфоны

Фильмы

Путешествия

Археология

Музыка

Мода

Сериалы

Здоровье

Рекомендации

[Показать больше](#)

РЕКЛАМА



Подписка
Секретарь +

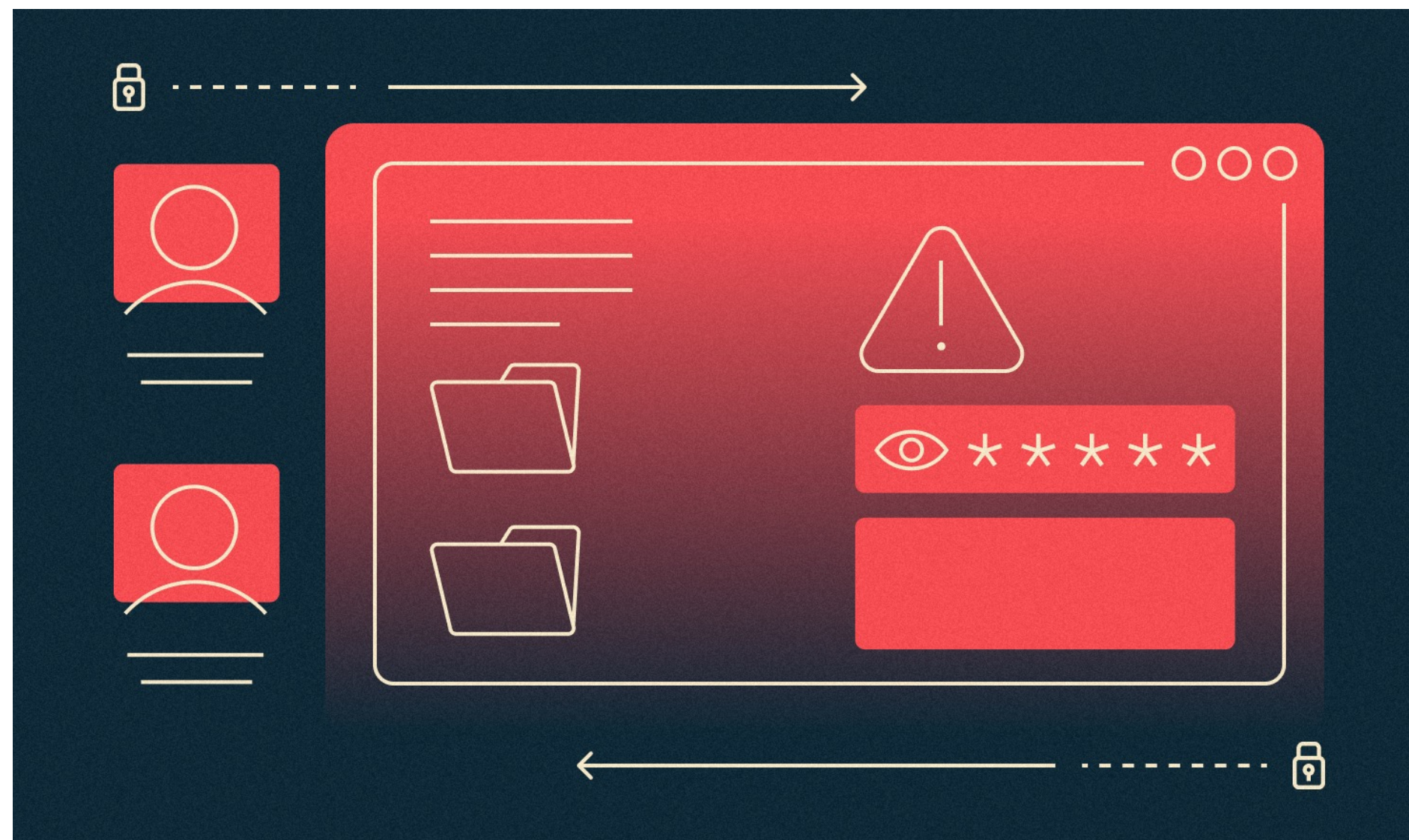
В 2024 году резко выросло количество скомпрометированных персональных данных — утекло более 1,5 млрд записей. Рост составил больше 30% по сравнению с 2023 годом. Такие подсчеты приводит экспертно-аналитический центр (ЭАЦ) ГК InfoWatch в своем исследовании «[Россия: утечки информации ограниченного доступа, 2023-2024](#)». Лидером по числу утечек стала сфера торговли, которая включает в себя как офлайн-, так и онлайн-ритейл. Почти треть из всего объема ПДн — это аутентификационная информация: пароли и логины, в том числе номера телефонов и адреса электронной почты.

За год из российских компаний утекло 1,581 млрд записей персональных данных — рост составил больше 30% по сравнению с 2023 годом, когда в сеть попали 1,202 млрд записей ПДн. В это же количество вошла одна утечка на 500 млн записей, о которой сообщал Роскомнадзор в начале 2024. Деталей этого происшествия, как и опровержения или дополнительного подтверждения, не последовало, отмечают авторы исследования.

- Проверка деятельности компании после инцидента, того, какие меры были внедрены. С учетом мнений специалистов в данной сфере.
- Мало перечисления прав, важны гарантии в киберсфере через реализацию безопасности персональных данных в киберсреде (принятие соответствующих мер защиты).



Привлечение специалистов для проверок систем, ликбез по кибербезопасности для сотрудников, пароли-защиты.



получит меньший штраф», — советует Филатов.

Алгоритм действий

Георгий Габолаев, генеральный директор «Группа-А», специально для «Сферы» написал небольшую инструкцию, которая поможет быстро адаптироваться к нововведениям:

- Уведомлять РКН об утечках. «Согласно новым требованиям, компании обязаны сообщать о фактах утечки данных в Роскомнадзор. Это нужно сделать в кратчайшие сроки (как правило, не позднее 24 часов)», — поясняет он.
- Обеспечить кибербезопасность. Использовать современные антивирусные программы и системы защиты.
- Регулярно обновлять программное обеспечение.
- Шифровать данные, чтобы их нельзя было использовать в случае утечки.
- Обучить персонал. «Большинство утечек происходит из-за человеческого фактора. Регулярное обучение сотрудников основам кибербезопасности и правилам обработки данных — обязательный шаг», — отмечает эксперт.
- Вести документацию. Важно фиксировать все процессы, связанные с обработкой данных. Это поможет доказать добросовестность компании в случае претензий.
- Проводить аудит систем обработки данных. Регулярная проверка IT-инфраструктуры на уязвимости позволяет предотвратить утечки до их возникновения.